Mestrado em Engenharia Informática
Gestão de Identidade

Semana 1 — Fundamentos de Identidade Digital

Ricardo Costa
rcosta@estg.ipp.pt
Escola Superior de Tecnologia e Gestão do Instituto Politécnico do Porto

Objetivos da Semana 1

No final da semana os estudantes deverão conseguir:

- Definir identidade digital e os seus elementos
- Diferenciar identificação, autenticação e autorização
- Explicar o papel da identidade como novo perímetro
- Compreender os blocos de uma arquitetura IAM
- Reconhecer riscos-base e respetivas mitigações
- Preparar ambiente laboratorial para as próximas semanas

Agenda (4h)

- **Parte Teórica (2h)**
  - Conceitos fundamentais
  - Arquitetura IAM
  - Modelos de autorização
  - Riscos e mitigação
- **Parte Prática (2h)**
  - Setup técnico do laboratório
  - Validação local do ambiente

Porque IAM importa?

Pergunta central:

> Qual é hoje o verdadeiro perímetro de segurança?

- O perímetro deixou de ser apenas a rede
- O controlo deslocou-se para **identidade + contexto + política**

Mudança de paradigma

Modelo antigo:

- Dentro da rede = confiável
- Fora da rede = não confiável

Modelo atual (Zero Trust):

- Nunca confiar implicitamente
- Verificar continuamente

O que é Identidade Digital?

Definição:

- Conjunto estruturado de atributos associados a uma entidade
- Permite representar, distinguir e governar acessos

Perguntas-chave:

1. Quem és?
2. Como provas que és tu?
3. O que podes fazer?

Elementos de identidade

- **Entidade**: pessoa, aplicação, serviço, dispositivo
- **Identificador**: valor único (username, UUID)
- **Atributo**: propriedade descritiva (email, função)
- **Credencial**: prova de identidade (password, token, certificado)

Conta ≠ Identidade

- **Identidade**: conceito organizacional transversal
- **Conta**: representação da identidade num sistema específico

Exemplo:

- A mesma pessoa pode ter conta em Moodle, email, ERP e VPN.

Problemas comuns

- Contas órfãs
- Shadow accounts
- Duplicação de identidades
- Atributos inconsistentes entre sistemas

Identificação, Autenticação e Autorização

- **Identificação**: “Eu sou X”
- **Autenticação**: “Provo que sou X”
- **Autorização**: “Posso fazer Y no recurso Z?”

Exemplo end-to-end

1. Username -> identificação
2. Password + MFA -> autenticação
3. Verificação de perfil/permissões -> autorização
4. Registo em logs -> accounting

AAA

- Authentication
- Authorization
- Accounting

> Sem accounting não há segurança verificável.

Accounting — para que serve?

- Registar quem acedeu, quando, a que recurso e com que resultado
- Garantir rastreabilidade de ações (incluindo administrativas)
- Suportar auditoria, compliance e investigação de incidentes
- Produzir evidência para responder a: “quem fez o quê?”

Accounting — exemplos de eventos

- Login bem-sucedido/falhado
- Alteração de permissões/roles
- Acesso a dados sensíveis
- Operações críticas (ex: exportação de dados)

Menor privilégio e SoD

- **Menor privilégio**: apenas acesso estritamente necessário
- **Segregação de funções (SoD)**: evitar concentração de poder na mesma identidade

Arquitetura IAM — visão geral

1. Identity Store
2. Authentication Service
3. Authorization Engine
4. Federation Layer
5. Logging & Audit

Identity Store

Pode ser:

- LDAP / Active Directory
- Keycloak / Entra ID
- Serviço cloud

Contém:

- Identificadores
- Atributos
- Estado da identidade
- Ligações a grupos/perfis

Ciclo de vida (JML)

- **Joiner**: criação de identidade e acessos iniciais
- **Mover**: alterações por mudança de função
- **Leaver**: revogação/remoção de acessos

Risco crítico: falhas no Leaver.

Authentication Service

Valida que a entidade é quem diz ser.

Métodos:

- Password
- MFA
- Certificados
- WebAuthn/FIDO2

O que é MFA? (conceito)

MFA (Multi-Factor Authentication)

- Uso de 2 ou mais fatores independentes para autenticar

Tipos de fatores:

1. Algo que sabes (password, PIN)
2. Algo que tens (telemóvel, token físico)
3. Algo que és (biometria)

MFA (exemplos e limites)

Exemplos:

- Password + código TOTP
- Password + push notification
- Passwordless com chave FIDO2

MFA reduz muito risco, mas não elimina:

- Phishing avançado
- Engenharia social
- MFA fatigue

Authorization Engine

Decide o que a identidade pode fazer, com base em:

- papel
- atributos
- contexto
- políticas

Modelos comuns:

- RBAC
- ABAC
- Policy-based / ACL

O que é RBAC?

RBAC (Role-Based Access Control)

- Permissões são atribuídas a **roles/papéis**
- Utilizadores herdam permissões via role

Exemplo:

- Role “Docente” -> lançar notas, aceder a turmas
- Role “Aluno” -> consultar materiais e avaliações

RBAC (vantagens e limitações)

Vantagens:

- Simples de entender e implementar
- Bom para estruturas estáveis

Limitações:

- Explosão de roles (role sprawl)
- Menos flexível para regras contextuais

O que é ABAC?

ABAC (Attribute-Based Access Control)

- Decisão de acesso baseada em atributos de:
  - utilizador
  - recurso
  - ação
  - contexto (hora, localização, dispositivo)

ABAC (exemplo)

Regra possível:

- Permitir acesso a pauta se:
  - utilizador.função = “docente”
  - recurso.uc = utilizador.uc
  - hora dentro da janela permitida

ABAC permite decisões granulares e dinâmicas.

O que é Policy-based Access Control?

Definição:

- A autorização é decidida por **políticas centralizadas**
- As aplicações perguntam ao motor de políticas: "permitir ou negar?"

Para que serve:

- Garantir decisões **consistentes** em vários sistemas
- Evitar duplicar regras em cada aplicação
- Alterar regras sem reescrever código em todo o ecossistema

Policy-based — Exemplo prático

Cenário:

- Universidade com Moodle, Portal Académico e API de pautas

Política central:

- Só docentes da UC podem alterar classificações
- Apenas no período de avaliação
- Apenas a partir de dispositivos institucionais

Vantagem:

- A mesma regra aplica-se de forma uniforme a todos os serviços

O que é ACL (Access Control List)?

Definição:

- Cada recurso mantém uma lista local de permissões

Exemplo:

- Recurso "ficheiro X":
  - userA -> leitura
  - userB -> escrita
  - grupoDocentes -> leitura/escrita

Uso típico:

- Simples e eficaz em sistemas pequenos ou recursos isolados

Policy-based vs ACL (quando usar)

ACL

- Bom para casos locais e simples
- Torna-se difícil de manter quando o número de recursos/sistemas cresce

Policy-based

- Melhor para ambientes distribuídos e com muitas regras
- Facilita auditoria, governação e compliance
- Ideal quando há necessidade de regras contextuais (tempo, localização, risco)

Federation Layer

Permite confiança entre sistemas.

Protocolos:

- SAML
- OAuth 2.0
- OpenID Connect

Federation Layer — Exemplo 1 (Google Login)

Cenário:

- Aplicação externa oferece “Continuar com Google”

Fluxo simplificado:

1. Utilizador clica em “Login com Google”
2. Aplicação redireciona para Google (IdP)
3. Google autentica utilizador
4. Google devolve token à aplicação
5. Aplicação cria sessão local sem guardar password Google

Federation Layer — Exemplo 2 (SSO Académico)

Cenário:

- Moodle, Email institucional e Portal académico com login único

Fluxo simplificado:

1. Utilizador autentica-se uma vez no IdP institucional
2. Serviços confiam no IdP
3. Acesso aos restantes sistemas sem novo login (SSO)

Benefício:

- Melhor experiência + controlo centralizado de políticas

Federation Layer — Exemplo 3 (B2B)

Cenário:

- Empresa A partilha aplicação com utilizadores da Empresa B

Abordagem:

- Empresa B autentica os seus utilizadores (IdP próprio)
- Empresa A confia nos tokens/asserções da Empresa B
- Empresa A aplica autorização local

OAuth2 vs OIDC

- OAuth2 -> autorização (delegação)
- OIDC -> autenticação (identidade do utilizador)

Regra prática:

- “Quem é?” -> OIDC
- “Pode aceder a quê?” -> OAuth2 + políticas

Logging e Auditoria

Registar:

- Logins sucesso/falha
- Alterações de privilégios
- Ações administrativas
- Acessos a recursos sensíveis

Sem logs não há deteção, forense nem compliance robusto.

Riscos IAM mais comuns

- Credential stuffing
- Password reuse
- Ausência de MFA
- Privilégios excessivos
- Offboarding incompleto
- Tokens/segredos expostos

Credential Stuffing

- Uso automatizado de credenciais roubadas em vários serviços

Mitigação:

- MFA
- Rate limiting
- Deteção de anomalias
- Higiene de credenciais

Caso de discussão (10 min)

Cenário:

- Ex-colaborador mantém acesso VPN ativo
- Conta comprometida usada para extrair dados

Perguntas:

1. O que falhou?
2. Que controlo teria evitado?
3. Que logs seriam essenciais?

Mini-quiz diagnóstico

1. OAuth2 é autenticação ou autorização?
2. MFA elimina phishing avançado?
3. Conta e identidade são sinónimos?
4. Diferença essencial entre RBAC e ABAC?
5. Quando ACL pode ser insuficiente?

Transição para parte prática

Objetivo:

> Garantir ambiente técnico consistente para os laboratórios seguintes.

Prática — Plano (2h)

1. Diagnóstico inicial (20 min)
2. Configuração base do sistema (35 min)
3. Ferramentas + hardening mínimo (35 min)
4. Validação local (30 min)

Prática — Pré-requisitos

- VM (VirtualBox/VMware) ou Docker
- Ubuntu Server 22.04/24.04
- Acesso administrativo
- Internet estável

Prática — Comandos de referência

```
sudo apt update && sudo apt -y upgrade
sudo hostnamectl set-hostname gi-lab01
sudo adduser giadmin
sudo usermod -aG sudo giadmin
sudo apt install -y openssh-server curl jq net-tools ldap-utils
hostnamectl
ip a
id giadmin
```

Prática — Checklist de validação

- Hostname definido
- Utilizador administrativo criado
- SSH ativo
- Ferramentas instaladas
- Snapshot “baseline-semana1” criado

Respostas do mini-quiz

1. Autorização
2. Não
3. Não
4. RBAC usa papéis; ABAC usa atributos/contexto
5. Em ambientes grandes/dinâmicos, manutenção e consistência tornam-se difíceis

Fecho da Aula

Mensagem-chave:

> IAM não é "só login" — é infraestrutura crítica de segurança e governação.

Preparação para Semana 2:

- Rever ciclo de vida de identidade (JML)
- Introdução prática a LDAP

Obrigado.